Northfield University Office of Information Technology

Data Classification and Handling Standard

Document ID: NU-IT-POL-002 **Version:** 2.1 **Effective Date:** January 15, 2026 **Last Reviewed:** December 1, 2025 **Document Owner:** Chief Information Security Officer (CISO) **Approved By:** Vice President for Information Technology & CIO

1.0 Purpose

The purpose of this Data Classification and Handling Standard is to establish a consistent framework for categorizing institutional data based on its sensitivity and criticality. By defining clear classification levels and corresponding handling requirements, Northfield University seeks to protect the confidentiality, integrity, and availability of all data assets while ensuring compliance with applicable federal and state regulations, contractual obligations, and institutional policies.

This standard provides data custodians, system administrators, faculty, staff, and authorized third parties with the guidance necessary to appropriately classify, store, transmit, access, retain, and dispose of university data throughout its lifecycle.

1.1 Scope

This standard applies to all data created, collected, stored, processed, transmitted, or disposed of in the course of Northfield University operations, regardless of format (electronic, paper, or other media). It covers all university constituents, including but not limited to:

- Full-time, part-time, and temporary employees
- Faculty and academic staff
- Students, including graduate research assistants
- Contractors, consultants, and third-party vendors with access to university data
- Affiliated researchers and visiting scholars

This standard applies to data residing on university-managed systems, personally owned devices used for university business, cloud-based platforms, and physical records. It should be read in conjunction with the **Northfield University Acceptable Use Policy (NU-IT-POL-001)**, the **Information Security Policy (NU-IT-POL-005)**, and the **Third-Party Vendor Risk Management Policy (NU-IT-POL-011)**.

1.2 Definitions

Term	Definition
Data Custodian	An individual or unit responsible for the technical management and safeguarding of data assets on behalf of the data owner.
Data Owner	The university official or department head with authority and accountability for a specific data set.
Data Steward	An individual responsible for the day-to-day management of data quality, metadata, and compliance within a functional area.
Encryption at Rest	The use of cryptographic algorithms to protect data stored on disk, database, or other persistent storage media.
Encryption in Transit	The use of cryptographic protocols (e.g., TLS 1.2+) to protect data as it moves across networks.
PII (Personally Identifiable Information)	Any information that can be used to distinguish or trace an individual's identity, either alone or when combined with other information.
Institutional Data	Any data created, collected, maintained, or disseminated in the course of university operations, research, or instruction.

1.3 Classification Framework Overview

Northfield University classifies all institutional data into **four levels** based on the potential impact of unauthorized disclosure, alteration, or loss. The four levels, from least to most sensitive, are:

Level	Classification	Impact of Unauthorized Disclosure
Level 1	Public	No adverse impact
Level 2	Internal	Minor operational impact

| **Level 3** | Confidential | Serious regulatory, legal, or reputational impact |
| **Level 4** | Restricted | Severe legal liability, regulatory penalties, or threat to individual safety |

Data owners are responsible for assigning the appropriate classification level to data under their stewardship. When a data set contains elements spanning multiple classification levels, the **entire data set must be classified at the highest applicable level** unless the sensitive elements can be reliably separated and independently secured.

2.0 Level 1 – Public Data

2.1 Definition

Level 1 (Public) data is information that has been approved for unrestricted public access and whose disclosure poses no risk of harm to the university, its affiliates, or any individual. This information is either explicitly designated for public release or is already freely available through public channels.

2.2 Examples

- Published course catalogs and academic calendars
- University marketing materials, press releases, and media kits
- Public-facing website content
- Campus maps and building directories
- Published annual reports and financial summaries approved for public distribution
- Job postings and publicly listed contact information for university offices
- Event announcements and publicly available research publications

2.3 Handling Requirements

Requirement Area	Level 1 – Public Standard
Encryption at Rest	**Not required.** Standard storage practices are sufficient. No encryption mandate applies to Level 1 data.
Encryption in Transit	Recommended but not required. HTTPS is encouraged for web-based distribution.
Access Control	No access restrictions required. Data may be freely shared.
Storage	May be stored on any university or personal system, public cloud service, or web platform. No special system restrictions apply.
Transmission	May be transmitted via any channel, including email, public websites, and social media.
Retention	Retain in accordance with university records management schedules. Default retention: minimum 1 year after last use unless otherwise specified by the applicable records schedule.
Disposal	Standard deletion is sufficient. No special destruction procedures required. Physical documents may be recycled.

2.4 Responsibilities

Data owners publishing Level 1 data must ensure the information has been reviewed and approved for public release by the appropriate authority (e.g., University Communications Office for press materials, Registrar's Office for academic calendars). Even though Level 1 data carries no confidentiality risk, data owners remain responsible for ensuring accuracy and timeliness of published information.

2.5 Level 2 – Internal Data

2.5.1 Definition

Level 2 (Internal) data is information intended for use within the Northfield University community that is not approved for public release but whose unauthorized disclosure would result in only minor adverse impact. This category serves as the **default classification** for institutional data that does not clearly fit into another level.

2.5.2 Examples

- Internal memoranda and meeting minutes
- Non-sensitive operational reports and departmental budgets (pre-approval)
- Internal email communications
- Draft documents and working papers
- Internal policy documents not yet approved for publication
- Building access schedules and maintenance logs

- Training materials intended for internal audiences
- Non-sensitive vendor correspondence

2.5.3 Handling Requirements

Requirement Area	Level 2 – Internal Standard
Encryption at Rest	**Recommended but not mandatory.** Systems that store large volumes of Level 2 data should implement encryption where feasible. University-managed endpoints with full-disk encryption satisfy this recommendation by default.
Encryption in Transit	Required for transmission over external networks. Use **TLS 1.2 or higher**. Internal network transmission without encryption is permissible but discouraged.
Access Control	Access limited to Northfield University faculty, staff, and authorized affiliates on a need-to-know basis. Authentication via university NetID credentials is required.
Storage	Must be stored on university-managed systems, university-approved cloud services (e.g., Northfield Google Workspace, Northfield Microsoft 365), or encrypted portable media. Storage on unapproved personal cloud services (e.g., personal Dropbox, personal Google Drive) is prohibited.
Transmission	May be transmitted via university email, approved collaboration platforms, or encrypted file transfer. Transmission to external parties requires approval from the data owner.
Retention	Retain in accordance with applicable records retention schedules. Default retention: 3 years after last use unless otherwise specified.
Disposal	Electronic data: secure deletion using approved sanitization tools. Physical documents: cross-cut shredding or secure shredding bins provided by Facilities Management.

3.0 Level 3 – Confidential Data

3.1 Definition

Level 3 (Confidential) data is information whose unauthorized disclosure, alteration, or destruction could result in significant harm to individuals, regulatory non-compliance, legal liability, or substantial reputational damage to Northfield University. This level encompasses data protected by federal and state laws, contractual obligations, and institutional policy.

3.2 Examples

- **Student educational records** protected under FERPA (e.g., transcripts, grades, enrollment status, class schedules, disciplinary records)
- Employee personally identifiable information (PII), including home addresses, phone numbers, dates of birth, and salary information
- Financial records, including departmental budgets post-approval, procurement records, and grant financial data
- Research data prior to publication or subject to data use agreements
- Donor and alumni records containing personal or giving information
- Legal correspondence and attorney-client privileged communications
- Intellectual property, including patent applications and proprietary research methodologies
- Non-public audit and compliance reports

3.3 Regulatory Framework

Student educational records, as defined by the **Family Educational Rights and Privacy Act (FERPA)**, are classified as **Level 3 (Confidential)**. Level 3 data must be encrypted at rest using **AES-256 or equivalent** and may only be stored on university-managed systems or approved cloud services with a signed data protection agreement.

Additional regulations governing Level 3 data include, but are not limited to:

- **FERPA** (20 U.S.C. § 1232g) – Student education records
- **GLBA** (Gramm-Leach-Bliley Act) – Financial information of individuals
- **New York State SHIELD Act** – Private information of New York residents
- **EU General Data Protection Regulation (GDPR)** – Personal data of EU/EEA residents, where applicable
- Institutional data use agreements and sponsored research contracts

3.4 Handling Requirements

Requirement Area	Level 3 – Confidential Standard
Encryption at Rest	**Required. AES-256 or equivalent encryption** must be applied to all Level 3 data at rest, whether stored on local drives, network storage, databases, or cloud platforms. Full-disk encryption alone is not sufficient for databases; column-level or application-level encryption is additionally required for fields containing regulated data.
Encryption in Transit	**Required.** All transmissions must use **TLS 1.2 or higher**. Email containing Level 3 data must use university-approved secure email solutions or encrypted attachments. Unencrypted transmission (e.g., standard FTP, HTTP) is strictly prohibited.
Access Control	Access restricted to authorized individuals with a documented, role-based need to know. University NetID authentication is required, plus **multi-factor authentication (MFA)** for all systems housing Level 3 data. Access must be reviewed by data owners at least **annually**.
Storage	Must be stored exclusively on **university-managed systems** or **approved cloud services** that have undergone security review and have a signed **data protection agreement (DPA)** on file with the Office of Information Security. Storage on personal devices, unapproved cloud services, or unencrypted removable media is prohibited. See the **Approved Cloud Services Registry (NU-IT-REG-003)** for the current list of vetted platforms.
Transmission	Transmission to external parties requires a signed **data sharing agreement** approved by the Office of General Counsel and the CISO. Internal transmission must use encrypted channels. Level 3 data must never be transmitted via unencrypted email, messaging applications, or unsecured file-sharing services.
Retention	Retain in accordance with specific regulatory requirements and university records retention schedules. FERPA records: retain for 5 years after the student's last date of attendance, or as required by applicable regulation, whichever is longer. Financial records: retain for 7 years per federal and state tax requirements.
Disposal	**Certified destruction required.** Electronic media: use NIST SP 800-88 compliant methods (e.g., cryptographic erasure, degaussing, or physical destruction). Physical documents: cross-cut shredding with a certificate of destruction. Disposal must be documented and records maintained for a minimum of 3 years.

3.5 Incident Reporting

Any suspected or confirmed unauthorized access to, disclosure of, or loss of Level 3 data constitutes a **data security incident** and must be reported immediately (within 1 hour of discovery) to the Northfield University Security Operations Center (SOC) at **security@northfield.edu** or by calling **(212) 555-4400**. Refer to the **Incident Response Policy (NU-IT-POL-007)** for detailed reporting and escalation procedures.

4.0 Level 4 – Restricted Data

4.1 Definition

Level 4 (Restricted) data is the most sensitive category of institutional data. Unauthorized disclosure, alteration, or destruction of Level 4 data could result in severe legal penalties, significant financial liability, regulatory sanctions, harm to individuals (including identity theft, financial fraud, or physical danger), or jeopardy to national security. Level 4 data is subject to the most stringent handling controls.

4.2 Examples

- **Social Security numbers (SSNs)** — whether full or partial (last four digits in combination with other PII)
- **Credit card numbers and payment card data** subject to the **Payment Card Industry Data Security Standard (PCI DSS)**
- **Protected health information (PHI)** as defined by the **Health Insurance Portability and Accountability Act (HIPAA)**
- Bank account and financial account numbers
- Passwords, PINs, and cryptographic keys
- Biometric data (fingerprints, retinal scans, facial recognition templates)
- **Export-controlled research data** subject to **ITAR (International Traffic in Arms Regulations)** or **EAR (Export Administration Regulations)**
- Data classified by the U.S. government (Controlled Unclassified Information or higher)
- Immigration documents and visa status information
- Criminal background check results

4.3 Regulatory Framework

Level 4 data is governed by the most stringent federal and state regulations, including:

Regulation / Standard	Data Type Covered
HIPAA (Health Insurance Portability and Accountability Act)	Protected health information (PHI)
PCI DSS (Payment Card Industry Data Security Standard)	Cardholder data, payment card numbers
ITAR (International Traffic in Arms Regulations)	Defense-related technical data
EAR (Export Administration Regulations)	Dual-use technologies and technical data
IRS Publication 1075	Federal tax information (FTI)
FERPA (in certain contexts)	SSNs when used as student identifiers (legacy systems)
NY Identity Theft Prevention Act	SSNs, financial account numbers

Violations of Level 4 data handling requirements may result in **criminal penalties, civil fines, loss of federal funding, and individual liability** in addition to university disciplinary action up to and including termination of employment or contract.

4.4 Handling Requirements

Requirement Area	Level 4 – Restricted Standard
Encryption at Rest	**Required. AES-256 encryption is mandatory, plus additional access controls.** Level 4 data must be encrypted at rest using AES-256 or stronger algorithms. In addition to encryption, **hardware security modules (HSMs)** or equivalent key management systems must be used for cryptographic key storage. Databases containing Level 4 data must implement both column-level encryption and transparent data encryption (TDE).
Encryption in Transit	**Required.** All transmissions must use **TLS 1.3** (TLS 1.2 accepted only where 1.3 is not technically feasible, with documented exception). VPN tunnels with AES-256 encryption are required for bulk data transfers. Email transmission of Level 4 data is **prohibited** unless using a FIPS 140-2 validated encryption solution approved by the CISO.
Access Control	Access restricted to specifically named individuals with documented authorization from the data owner **and** the CISO. **Multi-factor authentication (MFA) is mandatory.** Privileged access requires additional controls including **privileged access management (PAM)** tools. Access must be reviewed **quarterly** by both the data owner and the Office of Information Security. All access to Level 4 data must be logged with tamper-evident audit trails retained for a minimum of 6 years.
Storage	Must be stored exclusively on **hardened, university-managed systems** that have been specifically approved for Level 4 data by the CISO. Cloud storage of Level 4 data requires **FedRAMP Moderate (or higher) authorization** or equivalent certification, a signed Business Associate Agreement (for HIPAA data) or equivalent contractual protection, and explicit written approval from the CISO. Storage on personal devices, portable media, or unapproved systems is **strictly prohibited** under all circumstances.
Transmission	External transmission requires **written approval from the CISO** and a signed data sharing agreement reviewed by the Office of General Counsel. All transmissions must be logged. Transmission via standard email, instant messaging, SMS, or consumer-grade file sharing services is **prohibited**. Only university-approved secure transfer mechanisms (e.g., managed file transfer platforms, encrypted SFTP) may be used.

| **Retention** | Retain only for the minimum period required by applicable regulation, contract, or business need. HIPAA records: 6 years from date of creation or last effective date. PCI data: Cardholder data must not be stored post-authorization unless there is a documented business justification and it is stored in compliance with PCI DSS Requirement 3. SSNs: retain only as required by law; eliminate from all systems where not legally mandated. |

| **Disposal** | **Certified destruction with verification required.** Electronic media: NIST SP 800-88 Rev. 1 "Purge" or "Destroy" methods. Physical destruction (shredding, incineration, or disintegration) is required for media that cannot be reliably purged. A **certificate of destruction** signed by an authorized representative must be obtained and retained for 7 years. Third-party destruction vendors must be pre-approved by the CISO and must provide proof of NAID AAA certification or equivalent. |

5.0 Classification Summary Matrix

The following table provides a consolidated reference for the encryption and primary handling requirements across all four data classification levels:

Requirement	Level 1 (Public)	Level 2 (Internal)	Level 3 (Confidential)	Level 4 (Restricted)
Encryption at Rest	Not required	Recommended	**AES-256 required**	**AES-256 required + additional access controls (HSM key management)**
Encryption in Transit	Recommended (HTTPS)	Required over external networks (TLS 1.2+)	**Required (TLS 1.2+)**	**Required (TLS 1.3 preferred; VPN for bulk transfers)**
MFA Required	No	No	**Yes**	**Yes (plus PAM for privileged access)**
Access Review Frequency	N/A	As needed	**Annually**	**Quarterly**
Storage Restrictions	None	University-managed or approved cloud	University-managed or approved cloud with DPA	**Hardened systems with CISO approval**
Disposal Method	Standard deletion	Secure deletion / shredding	**Certified destruction (NIST SP 800-88)**	**Certified destruction with verification; 7-year record retention**

6.0 Data Classification Procedures

6.1 Initial Classification

All new data sets, applications, and systems must undergo a data classification assessment prior to deployment. The data owner, in consultation with the Office of Information Security, is responsible for completing the **Data Classification Assessment Form (NU-IT-FORM-002)** and submitting it to the CISO for review.

6.2 Reclassification

Data classification must be reviewed and updated when:

1. The nature or sensitivity of the data changes
2. Regulatory requirements change
3. A data set is merged with or linked to data of a different classification level
4. A contractual or grant obligation imposes new handling requirements
5. During periodic reviews (at minimum, every **two years** or upon contract/grant renewal)

Reclassification requests must be submitted through the **IT Service Management Portal** and approved by the data owner and the CISO.

6.3 Labeling

Data should be labeled with its classification level wherever practicable:

- **Electronic documents:** Include classification level in the document header or footer (e.g., "CONFIDENTIAL – Level 3")
- **Email:** Include classification level in the subject line prefix for Level 3 and Level 4 communications
- **Physical documents:** Stamp or label with classification level on each page
- **Systems and databases:** Register classification level in the university's **IT Asset Management System (NU-IT-SYS-004)**

6.4 Training Requirements

All individuals with access to Level 3 or Level 4 data must complete the **Data Handling and Security Awareness Training (NU-IT-TRN-003)** prior to being granted access and annually thereafter. Training completion records are maintained by the Office of Information Security and are subject to audit.

7.0 Roles and Responsibilities

Role	Responsibilities
Data Owner	Assigns classification level; authorizes access; ensures compliance with handling requirements; conducts periodic access reviews.

| **Data Custodian** | Implements technical controls (encryption, access control, backup); maintains systems in accordance with classification requirements; reports incidents. |

| **Data Steward** | Manages data quality; ensures metadata accuracy; supports classification and reclassification activities within functional area. |

| **CISO / Office of Information Security** | Develops and maintains classification standards; conducts security reviews; approves cloud services and third-party agreements; provides training and guidance. |

| **All Users** | Handle data in accordance with its classification level; complete required training; report suspected incidents immediately. |

8.0 Enforcement and Sanctions

Violations of this Data Classification and Handling Standard may result in disciplinary action in accordance with applicable university policies, up to and including:

- Revocation of system access and university computing privileges
- Formal reprimand or performance action through Human Resources
- Termination of employment or contract
- Referral to law enforcement where criminal activity is suspected
- Civil liability and regulatory penalties as applicable under federal and state law

Violations involving Level 4 data will be escalated to the Vice President for Information Technology, the Office of General Counsel, and relevant regulatory authorities as required by law.

9.0 Related Policies and References

- **NU-IT-POL-001** – Acceptable Use Policy
- **NU-IT-POL-005** – Information Security Policy
- **NU-IT-POL-007** – Incident Response Policy
- **NU-IT-POL-008** – Access Control and Identity Management Policy
- **NU-IT-POL-011** – Third-Party Vendor Risk Management Policy
- **NU-IT-REG-003** – Approved Cloud Services Registry
- **NIST SP 800-88 Rev. 1** – Guidelines for Media Sanitization
- **NIST SP 800-53 Rev. 5** – Security and Privacy Controls
- **FERPA** (20 U.S.C. § 1232g; 34 CFR Part 99)
- **HIPAA** (45 CFR Parts 160 and 164)
- **PCI DSS v4.0**
- **ITAR** (22 CFR Parts 120-130)
- **EAR** (15 CFR Parts 730-774)

10.0 Revision History

Version	Date	Author	Description
1.0	March 1, 2022	CISO Office	Initial publication
1.5	August 15, 2023	CISO Office	Added Level 4 cloud storage requirements; updated PCI DSS references to v4.0
2.0	June 1, 2025	CISO Office	Major revision: updated encryption standards, added GDPR considerations, revised disposal requirements
2.1	January 15, 2026	CISO Office	Updated TLS requirements for Level 4; added HSM key management requirement; clarified FERPA classification

---

Synthetic document for a take-home assignment. Not an official NYU policy. | Northfield University Office of IT